ENTERPRISE MOBILE PLATFORM

Tech Stack Reference

Microsoft Cloud Adoption Framework for Azure · 3–5 Year Horizon

Classification	Horizon	Platforms	Cloud
Enterprise / Internal	2025 – 2029	iOS · Android · Web	Microsoft Azure (primary)

1. Overview & CAF Alignment

This document defines the enterprise mobile technology stack for a 3–5 year planning horizon, structured against Microsoft's Cloud Adoption Framework (CAF). The stack is Azure-primary with deliberate portability boundaries to mitigate long-term lock-in risk. Each layer maps to a CAF motivational phase: Strategy, Plan, Ready, Adopt, Govern, and Manage.

1.1 Cloud Adoption Framework — Mobile Mapping

CAF Phase	Mobile Domain	Key Decisions in This Document
Strategy	Business motivation & mobile-specific goals	Platform target (iOS/Android/Web), native vs. cross-platform rationale, build vs. buy posture
Plan	Digital estate & skills readiness	App portfolio inventory, team capability gaps, Azure landing zone prerequisites
Ready	Azure Landing Zone	Subscription topology, network segmentation, IAM foundations, API gateway placement
Adopt (Migrate)	Lift & shift of existing mobile backends	API modernisation to Azure API Management, auth migration to Entra ID
Adopt (Innovate)	New mobile capabilities	React Native / .NET MAUI selection, offline-first patterns, push notification pipeline
Govern	Policy & compliance guardrails	Azure Policy assignments, MASVS controls, GDPR / HIPAA / SOC 2 mapping
Manage	Ongoing operations	OTel observability, crash triage, OTA update cadence, capacity planning

1.2 Guiding Principles

Principle	Statement	Implication
Azure-Primary	Azure is the default for all infrastructure and managed services	First-class use of Entra ID, APIM, Azure Monitor, App Service, AKS
Portability Boundaries	Avoid hard lock-in at the data and compute layers	OSS runtimes (Node/Kotlin/Swift), standard protocols (OAuth 2.0, OTel, OCI)
Security by Design	OWASP MASVS L2 baseline for all consumer apps	Threat modelling per release, RASP in production, SBOM on every build
Offline-First	Apps must function without connectivity for core workflows	CRDTs or last-write-wins sync, background reconciliation via Azure Service Bus
AI Boundary	AI confined to developer tooling & ops — not end-user product features	No LLM inference in the critical runtime path; GenAI limited to CI/CD and ops dashboards
Sustainability	All choices evaluated against a 3–5 year TCO and community health	Prefer CNCF-graduated, Microsoft-GA, or ECMA-standard technologies

2. Architecture Overview

The stack is organised into seven concentric governance rings. Each ring depends on the ones inside it, ensuring security and compliance controls are established before application-layer decisions are made.

2.1 Concentric Ring Model (Text Diagram)

```
┌──────────────────────────────────────────────────────────────────────────────┐
│ [7] OPERATIONS · Azure Monitor · OTel · Argo Rollouts │
│ ┌──────────────────────────────────────────────────────────────────────┐ │
│ │ [6] PRIVACY · Purview · GDPR/HIPAA · Data Residency │ │
│ │ ┌──────────────────────────────────────────────────────────────┐ │ │
│ │ │ [5] PLATFORM · AKS · APIM · Service Bus │ │ │
│ │ │ ┌──────────────────────────────────────────────────────┐ │ │ │
│ │ │ │ [4] APPLICATION · React Native · MAUI │ │ │ │
│ │ │ │ ┌──────────────────────────────────────────────┐ │ │ │ │
│ │ │ │ │ [3] DESIGN SYSTEM · Fluent UI │ │ │ │ │
│ │ │ │ │ ┌──────────────────────────────────────┐ │ │ │ │ │
│ │ │ │ │ │ [2] COMPLIANCE · MASVS · SOC2 │ │ │ │ │ │
│ │ │ │ │ │ ┌──────────────────────────────┐ │ │ │ │ │ │
│ │ │ │ │ │ │ [1] SECURITY · Entra ID │ │ │ │ │ │ │
│ │ │ │ │ │ │ ┌──────────────────────┐ │ │ │ │ │ │ │
│ │ │ │ │ │ │ │ [0] FOUNDATION │ │ │ │ │ │ │ │
│ │ │ │ │ │ │ │ Azure Landing Zone │ │ │ │ │ │ │ │
│ │ │ │ │ │ │ └──────────────────────┘ │ │ │ │ │ │ │
│ │ │ │ │ │ │ └──────────────────────────────┘ │ │ │ │ │ │
│ │ │ │ │ │ └──────────────────────────────────────┘ │ │ │ │ │
│ │ │ │ │ └──────────────────────────────────────────────┘ │ │ │ │
│ │ │ │ └──────────────────────────────────────────────────────┘ │ │ │
│ │ │ └──────────────────────────────────────────────────────────────┘ │ │
│ │ └──────────────────────────────────────────────────────────────────────┘ │
└──────────────────────────────────────────────────────────────────────────────┘
```

2.2 Data Flow Overview

```
Mobile Client (iOS / Android / Web)
    │
    │ HTTPS / mTLS
    ▼
Azure API Management (APIM) ──────────► Azure Entra ID (OIDC / PKCE)
    │ JWT validation · Rate limit · WAF
    │
    ├──► BFF / Microservices  (AKS / App Service)
    │       │
    │       ├──► Azure Cosmos DB  (online data)
    │       ├──► Azure Service Bus  (async events)
    │       └──► Azure Blob Storage  (media / assets)
    │
    └──► Push Notifications  (Azure Notification Hubs)

Device Local Store  ◄─────── Background Sync ──────► Service Bus / Cosmos
(SQLite / Room / CoreData)    (conflict resolution via CRDTs / LWW)
```

3. Foundation — Azure Landing Zone

The Landing Zone is the pre-requisite infrastructure layer. It enforces subscription topology, network segmentation, and IAM foundations before any mobile workload is deployed. CAF prescribes the Enterprise-Scale Landing Zone (ESLZ) blueprint.

3.1 Subscription Topology

Subscription	Purpose	Key Azure Services
Management	Central policy, logging, Security Center	Azure Policy, Defender for Cloud, Log Analytics Workspace, Azure Monitor
Identity	Centralised Entra ID & B2C tenants	Entra ID, Entra External ID (B2C), Entra Verified ID
Connectivity	Hub VNet, firewalls, DNS, ExpressRoute	Azure Firewall Premium, Private DNS Zones, VPN Gateway, DDoS Protection
Mobile-NonProd	Dev, test, staging environments	APIM (dev tier), AKS Dev, App Service (B/S tiers), Cosmos DB (serverless)
Mobile-Prod	Production workloads	APIM (Standard v2), AKS, App Service (P-tier), Cosmos DB (provisioned), Front Door
Security	SIEM, vulnerability management	Microsoft Sentinel, Defender for Containers, Key Vault (HSM), Purview

3.2 Network Architecture

Zone	CIDR (example)	Controls
Hub VNet	10.0.0.0/16	Azure Firewall, Bastion, DDoS Standard, Private DNS resolver
APIM Subnet	10.1.0.0/24	NSG: inbound 443 only from Front Door; APIM in internal mode
AKS System Pool	10.1.1.0/24	Azure CNI, NetworkPolicy (Calico), no public IP
AKS User Pool	10.1.2.0/23	Isolated from system pool; egress via Azure Firewall
App Service VNet Integration	10.1.4.0/24	Outbound via VNet injection; inbound via Private Endpoint
Data Subnet	10.1.5.0/24	Cosmos DB & Storage Private Endpoints only; no internet route

4. Security & Identity

4.1 Identity Platform

Scenario	Azure Service	Protocol / Standard	Notes
Employee (internal) auth	Entra ID	OAuth 2.0 + OIDC + PKCE	Conditional Access, MFA enforced at Entra level
Consumer (external) auth	Entra External ID	OAuth 2.0 + OIDC + PKCE	Custom UI via hosted pages; supports social IdPs
M2M / service-to-service	Entra ID — Managed Identity	Client Credentials + Workload Identity	No secrets in config; Federated Identity for AKS
Elevated authorisation	Entra ID — PAR (Pushed Auth Req)	RFC 9126	Prevents auth parameter tampering on public clients
Token storage (device)	iOS Keychain / Android Keystore	OS-native secure enclave	Never store tokens in SharedPreferences or NSUserDefaults
Certificate / secret mgmt	Azure Key Vault (HSM-backed)	PKCS#11 / REST	Auto-rotation policy; no secrets in CI/CD env vars

4.2 OWASP MASVS Control Mapping

All production mobile apps target MASVS Level 2. The table below maps critical MASVS categories to concrete Azure and OS-native controls.

MASVS Category	Requirement	Implementation
MASVS-STORAGE	No sensitive data in plaintext on device	Keychain (iOS) / Keystore (Android); encrypted SQLite via SQLCipher; Key Vault for server secrets
MASVS-CRYPTO	Strong, up-to-date algorithms only	AES-256-GCM, RSA-2048+, TLS 1.3 minimum; no MD5/SHA-1; Key Vault for key material
MASVS-AUTH	Proper session management	Short-lived JWTs (15 min access / 24 h refresh); silent refresh via MSAL; revocation via Entra CAE
MASVS-NETWORK	Certificate pinning & TLS hardening	HSTS + Certificate Transparency; APIM WAF enforces TLS 1.3; dynamic pinning via Entra
MASVS-CODE	Anti-tampering & obfuscation	RASP (Runtime Application Self-Protection) SDK; code obfuscation (R8/ProGuard, Swift obfuscation)
MASVS-RESILIENCE	Runtime integrity checks	Jailbreak/root detection; debugger detection; binary integrity via code signing (Apple/ Google)

4.3 Token Lifecycle

1. App initiates PKCE authorisation code flow via MSAL
2. PAR request sent to Entra ID (RFC 9126) — prevents param tampering
3. Authorisation code returned, exchanged for access token (15 min)
+ refresh token (24 h, refresh token rotation enabled)
4. Access token presented to APIM as Bearer in Authorization header
5. APIM validates JWT signature against Entra JWKS endpoint
6. Continuous Access Evaluation (CAE): Entra revokes token in-flight
if user risk changes (sign-in anomaly, credential change)
7. MSAL silent refresh acquires new access token before expiry
8. On sign-out: token cache cleared from OS secure store

5. Client Layer — Mobile Application

5.1 Platform Selection Matrix

Factor	React Native (JSI/ Fabric)	.NET MAUI	Native (Swift/Kotlin)	Recommendation
Code sharing	~80% shared JS/TS	~90% shared C#	0% (separate codebases)	React Native / MAUI
Performance	Near-native via Fabric renderer	Near-native via .NET handlers	Full native	Native for perf-critical
Ecosystem	Largest OSS ecosystem	Tight Microsoft / Azure SDK integration	Platform-specific, best tooling	React Native for breadth
Microsoft alignment	Moderate (no first-party SDK)	First-class (Microsoft-owned)	N/A	MAUI if .NET shop
Long-term support	Meta-backed, CNCF-adjacent	Microsoft GA, .NET 8 LTS	Apple / Google sustained	All viable at 5 years
Team skills	JS/TS: broad talent pool	C#/.NET: enterprise-common	Platform-specific specialists	Evaluate per org
CAF alignment	Moderate — JS runtime portability	Strong — Azure SDK, Entra MSAL first-class	Strong — native platform intent	MAUI preferred if Azure-first

5.2 React Native Architecture (if selected)

Component	Technology	Role
JS Engine	Hermes (default in RN 0.70+)	Optimised for mobile startup; AOT bytecode compilation
Renderer	Fabric (new architecture)	Concurrent rendering; synchronous native view mutations
Native Modules	TurboModules + JSI	Synchronous C++ bridge; eliminates async JSON serialisation overhead
Navigation	React Navigation v7	Stack, tab, drawer; deep-link capable; typed routes
State management	Zustand + React Query (TanStack)	Zustand for global UI state; React Query for server-state cache & sync
Auth	MSAL React Native	Microsoft-official OAuth 2.0/OIDC; integrates with Entra ID
Offline DB	WatermelonDB or SQLite (op-sqlite)	Observable reactive queries; SQLCipher for encryption at rest
Push notifications	Notifee + Azure Notification Hubs SDK	Rich notifications; FCM/APNs abstraction via ANH

5.3 .NET MAUI Architecture (if selected)

Component	Technology	Role
Runtime	.NET 8 (LTS) — NativeAOT for mobile	Minimal runtime overhead; reduced app size
UI Framework	.NET MAUI Handlers + Fluent UI components	Cross-platform native controls; no WebView dependency
Auth	MSAL.NET	First-class Entra ID & Entra External ID; token caching via OS secure store
API client	Kiota-generated typed clients	Microsoft's OpenAPI code generator; integrates with Azure API Center
Offline DB	SQLite-net-pcl + SQLCipher	ORM for local data; encrypted at rest
State	MVVM Community Toolkit + .NET Observables	INotifyPropertyChanged automation; data binding
Push	Azure Notification Hubs SDK for .NET	First-class ANH integration; rich notification handling
Telemetry	Application Insights SDK (Azure Monitor)	Crash, performance, custom events to Azure

6. API & Backend Platform

6.1 API Gateway — Azure API Management

APIM Capability	Configuration	Mobile-Specific Purpose
JWT Validation	validate-jwt policy; Entra ID JWKS endpoint	Offloads token verification from microservices; single enforcement point
Rate Limiting	rate-limit-by-key per client_id	Prevents DDoS from compromised devices; per-user throttle
WAF	Azure Front Door WAF + APIM in internal mode	OWASP rule sets; bot protection; geo-filtering
API Versioning	Header-based versioning (api-version header)	Supports simultaneous old/new client versions during rollouts
Response Caching	cache-lookup / cache-store policies	Reduces backend load for reference-data endpoints
Subscription Keys	Managed via APIM Products; client apps use Entra token (not sub keys)	Sub keys for backend-to-backend; Entra Bearer for mobile clients
Developer Portal	Built-in APIM dev portal with API catalog	Internal API discovery; auto-generated SDK stubs via Kiota
Mock Responses	return-response policy	Enables frontend parallel development against stable contracts

6.2 Backend Compute

Workload Type	Azure Service	Runtime	Rationale
BFF (Backend for Frontend)	Azure App Service (P1v3+)	Node 20 LTS / .NET 8	Low-latency mobile-tailored aggregation layer; slots for blue-green deploys
Microservices (stateless)	AKS (Azure Kubernetes Service)	Containerised (OCI)	KEDA autoscaling; workload identity; Azure CNI networking
Event-driven processing	Azure Functions (Flex Consumption)	.NET 8 isolated / Node 20	Cost-efficient for burst workloads; triggers from Service Bus & Event Grid
Background jobs / sync	Azure Container Apps (KEDA)	.NET 8 / Node 20	Offline sync reconciliation; KEDA-driven horizontal scale
Real-time (WebSocket/ SSE)	Azure SignalR Service	Hub-based	Mobile push-style events without polling; Entra auth integration

6.3 Async Messaging

Pattern	Azure Service	Use Case
Command / RPC async	Azure Service Bus (Standard+)	Mobile-initiated long-running operations; at-least-once delivery; dead-letter queue
Event streaming	Azure Event Hubs	High-throughput telemetry ingest from device fleet; Kafka-compatible consumers
Change feed / CDC	Cosmos DB Change Feed	Propagate data changes to downstream services and offline sync reconciler
Pub/Sub fan-out	Azure Event Grid	Cross-service event routing; webhook delivery to external partners
Push to device	Azure Notification Hubs	FCM (Android) + APNs (iOS) abstraction; tag-based targeting; silent push for sync wake

7. Data Layer

7.1 Data Store Selection

Data Type	Primary Store	Tier / Config	Key Properties
Transactional / document	Azure Cosmos DB for NoSQL	Provisioned RU/s; multi-region writes	99.999% availability; 10ms p99 reads; tunable consistency
Relational (backend)	Azure Database for PostgreSQL — Flexible	Burstable → General Purpose	ACID; PostGIS; row-level security; pgvector for embeddings
Device local (offline)	SQLite + SQLCipher	App-bundled	Encrypted at rest; WAL mode; reactive queries via WatermelonDB
Binary / media assets	Azure Blob Storage (Hot/Cool/Archive)	ZRS or GRS redundancy	CDN via Azure Front Door; SAS URL for direct device download
Key-value cache	Azure Cache for Redis (Enterprise)	Geo-replication	Sub-ms latency for session and reference data; RESP3 protocol
Search	Azure AI Search	Standard S1+	Full-text + vector hybrid search; mobile-friendly REST API
Time-series / telemetry	Azure Data Explorer (ADX)	Dev → Standard	Device telemetry analytics; KQL; long-retention cost-efficient

7.2 Offline-First Sync Architecture

Offline capability requires three concerns: local persistence, conflict resolution, and background synchronisation. The architecture below applies to both React Native (WatermelonDB) and MAUI (SQLite-net).

```
┌──────────────────────────────────────────────────────────────────────┐
│ Device Local Layer                                                   │
│  SQLite (SQLCipher) — encrypted local replica                        │
│  Change log table: { entity, id, op, vector_clock, payload }         │
└──────────────────────────────────┬───────────────────────────────────┘
                                   │ Background Sync Worker
                                   │ (triggered by push / timer / reachability)
┌──────────────────────────────────▼───────────────────────────────────┐
│ Sync Endpoint (BFF / Container App)                                  │
│  1. Pull changes from Cosmos DB Change Feed since watermark          │
│  2. Push local change log batch to Service Bus                       │
│  3. Conflict resolution: Server-wins or CRDT merge                   │
│  4. Return resolved state to device; update watermark                │
└──────────────────────────────────────────────────────────────────────┘
```

Conflict Strategy	When to Use	Azure Component
Last-Write-Wins (LWW)	Simple data with low contention (e.g. user preferences)	Cosmos DB optimistic concurrency (etag); server timestamp
CRDT (Conflict-free Replicated)	Collaborative / high-contention data (e.g. shared lists)	Custom merge logic in sync BFF; Cosmos DB stores CRDT state
Client-Wins	Offline-first UX where device is authoritative	Service Bus receives delta; Cosmos DB upsert with device version
Manual Resolution	Critical data requiring human review (e.g. medical records)	Service Bus dead-letter queue; Operations dashboard in Azure Monitor

8. DevOps & CI/CD Pipeline

8.1 Pipeline Architecture

```
Developer Commit
    │
    ▼
GitHub / Azure DevOps Repos  (monorepo — Nx or Turborepo)
    │
    ▼
Build Pipeline  (GitHub Actions + Azure Pipelines hybrid)
  ├── Static Analysis:  ESLint / SonarQube / Detekt / SwiftLint
  ├── SAST:             Semgrep (MASVS rules) + Microsoft Defender DAST
  ├── Dependency scan:  Dependabot + SBOM generation (Syft → CycloneDX)
  ├── Unit / Component: Jest / XCTest / JUnit 5
  ├── Contract tests:   Pact (consumer-driven; APIM contract source)
  ├── Build artefacts:  Gradle / Xcode Cloud / EAS Build (RN)
  └── Container build:  ko / Docker Buildx → Azure Container Registry
    │
    ▼
Release Pipeline  (Argo CD + Azure Pipelines)
  ├── Non-prod:  GitOps → AKS (Argo CD) → smoke tests
  ├── Prod:      Argo Rollouts (canary 5% → 25% → 50% → 100%)
  ├── Mobile OTA: EAS Update (RN) / App Center CodePush (MAUI)
  └── App Store:  Fastlane (iOS + Android) → App Store Connect / Play
```

8.2 Toolchain Reference

Stage	Tool / Service	Azure Integration	Notes
Source control	GitHub Enterprise / Azure DevOps	Native OIDC federation	Monorepo recommended; branch policies enforced
Build orchestration	GitHub Actions + Azure Pipelines	Azure Managed DevOps Pools	Hybrid: GH Actions for open tasks; ADO for regulated
Artefact registry	Azure Container Registry (ACR)	Geo-replication; Private Link	OCI images + Helm charts; ACR Tasks for base image rebuild

Stage	Tool / Service	Azure Integration	Notes
Secret management	Azure Key Vault + GitHub OIDC	Federated identity; no stored secrets	OIDC workload identity — eliminates long-lived PATs
IaC	Bicep (primary) + Terraform (OSS fallback)	ARM-native Bicep; AzureRM Terraform provider	Bicep for Azure-specific; Terraform modules for portability
GitOps engine	Argo CD	AKS Add-on available	CNCF Graduated; reconciliation loop every 3 min
Progressive delivery	Argo Rollouts	Integrated with APIM and Azure Monitor metrics	Canary + blue-green; auto-rollback on p99 regression
Mobile CI	Xcode Cloud (iOS) + Gradle Enterprise (Android)	Artifacts to ACR / Blob Storage	Platform-native build agents; faster than generic runners
SBOM	Syft + Grype	Azure Policy + Defender for Containers scan	CycloneDX 1.5 format; ingested to Microsoft Defender

9. Observability & Operations

9.1 OTel Signal Map

Signal	Collection Method	Backend	Retention
Traces	OTel SDK (auto-instrumentation: Node, .NET, RN)	Azure Monitor Application Insights	90 days hot; ADX for long-term
Metrics	OTel Collector → Prometheus → Azure Monitor	Azure Managed Prometheus + Grafana	30 days hot; configurable
Logs	Structured JSON → OTel Collector → OTLP	Azure Log Analytics Workspace	30–90 days; tiered to cheap storage
Mobile Crashes	Firebase Crashlytics or Sentry (self-hosted)	Forwarded to Log Analytics via Logic App	90 days; alerting via Azure Monitor
Real-User Monitoring	App Center / Azure App Insights JS SDK	Application Insights	Funnel analysis; retention = 90 days
Synthetics	Azure Monitor — Availability Tests	Application Insights availability blade	Geo-distributed probes; alerting
Security events	Microsoft Defender for Cloud	Microsoft Sentinel (SIEM)	1 year default; SOAR playbooks

9.2 Alerting & SLO Strategy

SLO	Target	Azure Alert Configuration
API p99 latency (APIM)	< 400 ms	Azure Monitor Metric alert on APIM backend duration; 5-min evaluation window
App crash-free session rate	> 99.5%	Crashlytics / Sentry alert webhook → Logic App → Teams / PagerDuty
Push notification delivery	> 99%	Azure Notification Hubs telemetry; alert on failed-delivery ratio
Background sync success rate	> 98%	Custom metric from sync Container App; Azure Monitor alert
Auth token issue latency	< 200 ms	Entra ID sign-in logs → Log Analytics; alert on p99 query
AKS node CPU utilisation	< 70% sustained	Azure Monitor for containers; KEDA triggers scale before breach

10. Compliance & Governance

10.1 Regulatory Framework Mapping

Regulation	Scope	Azure Control Plane	Mobile-Specific Control
GDPR	EU personal data	Purview Data Map; Data Residency; Entra consent framework	On-device data minimisation; consent UI in app; right-to-erasure via Cosmos DB TTL
HIPAA	US protected health info (PHI)	Azure HIPAA BAA; Defender for Cloud; Encrypted transit + rest	No PHI in logs; minimum device caching; remote wipe via MDM
SOC 2 Type II	Security, availability, confidentiality	Defender for Cloud; Log Analytics; Change tracking	SBOM per build; MASVS L2 audit; CI/CD access controls
ISO 27001	ISMS	Azure Policy initiative: ISO 27001	Asset inventory via Defender; incident response playbooks in Sentinel
PCI DSS v4	Cardholder data (if applicable)	Azure Payment HSM; Defender; APIM WAF	No card data stored on device; tokenisation via Azure Key Vault

10.2 Azure Policy Assignments (Mobile Workloads)

Policy Initiative	Assignment Scope	Key Effects
CIS Microsoft Azure Foundations Benchmark	Mobile-Prod subscription	Deny public blob access; enforce Key Vault soft-delete; require HTTPS
NIST SP 800-53 R5	Management + Mobile subscriptions	Audit logging; access control; configuration management
Mobile MASVS Compliance (custom)	Mobile-Prod resource group	Deny App Service without HTTPS-only; deny storage without encryption; audit secrets in config
Defender for DevOps	Azure DevOps org / GitHub org	SBOM validation; secret scanning in PRs; dependency vulnerability gating
Entra ID CAE Policy	Entra tenant	Token revocation within 15 min of risk event; MFA step-up for sensitive ops

10.3 MDM / EMM Integration

For enterprise device management, the platform integrates with Intune via the Microsoft Intune App SDK (MAM) for managed app policies, independent of device enrolment (BYOD-compatible).

MDM Capability	Azure / Microsoft Service	Notes
Mobile Application Management (MAM)	Microsoft Intune — App Protection Policies	Data loss prevention; copy/paste restrictions; PIN enforcement without full MDM enrolment
Device Compliance Gating	Intune Compliance Policy + Entra Conditional Access	Non-compliant devices blocked from APIM; compliance signal fed to Entra risk engine
Managed App Config	Intune Managed App Config (AppConfig standard)	Server URL, feature flags, and environment config pushed OTA without app update
Remote Wipe / Selective Wipe	Intune selective wipe for MAM apps	Removes corporate data only; preserves personal data (BYOD-safe)
Certificate Delivery	Intune SCEP / PKCS profiles	Mutual TLS client certificates provisioned to managed apps

11. Full Stack Reference Table

Consolidated view of all selected technologies across every layer, with Azure mapping and sustainability assessment.

Layer	Component	Selected Technology	Azure Service / Integration	3–5 Yr Sustainability
Foundation	Landing Zone	Enterprise-Scale LZ blueprint	Management Groups + Azure Policy	Microsoft-strategic; long-term commitment
Foundation	IaC	Bicep (primary), Terraform (fallback)	Azure Resource Manager	Bicep: MS-strategic; TF: CNCF stable
Identity	Consumer auth	Entra External ID (B2C replacement)	Entra External ID	GA 2024; Microsoft long-term investment
Identity	Employee auth	Entra ID + MSAL	Entra ID	Core Microsoft platform; 10+ yr horizon
Identity	Secret store	Azure Key Vault (HSM)	Key Vault Managed HSM	FIPS 140-2 Level 3; stable GA product
Security	Runtime protection	RASP SDK (Guardsquare / Promon)	Integrated via APIM + Defender signals	Commercial; evaluate yearly
Security	SAST / DAST	Semgrep + Microsoft Defender DAST	Defender for DevOps (GH/ ADO integration)	Strong OSS + MS-native combination
Client — Cross-platform	Framework	React Native (Fabric) or .NET MAUI	Azure SDK first-class on both	Both: strong 5-yr outlook
Client — Auth	Auth SDK	MSAL React Native / MSAL.NET	Entra ID, Entra External ID	Microsoft-official; long-term support
Client — Offline DB	Local storage	SQLite + SQLCipher (WatermelonDB/SQLite-net)	N/A (device-local)	Widely used; stable; no lock-in
API Gateway	Gateway	Azure API Management (Standard v2)	APIM + Front Door + WAF	Strategic Azure product; v2 = modern SKU
Backend — BFF	Runtime	Node 20 LTS / .NET 8	Azure App Service P-tier	Both LTS; strong ecosystem
Backend — Services	Container runtime	AKS (Kubernetes 1.29+)	AKS + KEDA + Workload Identity	CNCF Graduated; multi-year roadmap
Backend — Async	Message broker	Azure Service Bus (Standard)	Service Bus + Event Grid	Mature; AMQP standard; stable
Data — Primary	Document DB	Azure Cosmos DB for NoSQL	Cosmos DB multi-region	Microsoft-strategic; 99.999% SLA

Layer	Component	Selected Technology	Azure Service / Integration	3–5 Yr Sustainability
Data — Relational	RDBMS	Azure Database for PostgreSQL Flex	Managed PG 16+	Open-source PG; Azure managed
Data — Cache	Cache	Azure Cache for Redis (Enterprise)	Redis Stack (vector + JSON)	Redis Labs + Microsoft partnership
Data — Search	Search engine	Azure AI Search	Integrated with Cosmos + Blob	Strategic Azure service
DevOps	CI/CD	GitHub Actions + Azure Pipelines	Azure Managed DevOps Pools	Both long-term GitHub/Microsoft
DevOps	GitOps	Argo CD + Argo Rollouts	AKS Add-on (Flux alt)	CNCF Graduated; progressive delivery
DevOps	Artefacts	Azure Container Registry	ACR + Artifact Cache	Azure-strategic; OCI compliant
Observability	Telemetry SDK	OpenTelemetry (OTel)	Azure Monitor OTel exporter	CNCF Graduated; vendor-neutral
Observability	APM / Metrics	Azure Monitor + Managed Prometheus	Grafana + Azure Monitor	First-class Azure stack
Observability	SIEM	Microsoft Sentinel	Sentinel + Defender XDR	Microsoft-strategic; SOAR included
Compliance	Policy engine	Azure Policy + Defender for Cloud	Built-in initiatives (CIS, NIST)	Core Azure governance; stable
Compliance	SBOM	Syft + Grype (CycloneDX)	Defender for Containers integration	CNCF ecosystem; industry standard
Notifications	Push gateway	Azure Notification Hubs	ANH + FCM/APNs	Managed abstraction; stable service
MDM / EMM	App management	Microsoft Intune (MAM/ MDM)	Entra CA + Intune compliance	Microsoft 365 core; long-term

12. 3–5 Year Sustainability Assessment

12.1 Technology Risk Register

Technology	Risk	Likelihood	Mitigation
React Native	Meta prioritisation shift; Fabric adoption lag in OSS plugins	Low	Vendor-diversify: MAUI readiness maintained; JSI boundary limits blast radius
Cosmos DB	Cost escalation at high RU/s; pricing model changes	Medium	Design schema for RU efficiency; budget alerts; evaluate Postgres for relational workloads
APIM Standard v2	v2 SKU feature parity gaps vs. Premium (no multi-region in v2)	Medium	Plan Premium upgrade at >1M req/day; architect for single-region v2 initially
Hermes JS engine	Debugging tooling maturity vs. V8	Low	OTel traces reduce dependency on JS engine debugger; Flipper for dev builds
Argo CD / Rollouts	Operator overhead in small teams	Medium	Azure Flux GitOps as fallback (native AKS add-on); simpler deployment gates
RASP SDK (commercial)	Vendor lock-in; annual licence cost	Medium	Annual RFP; evaluate Google Play Integrity API + Apple DeviceCheck as partial OSS alternative
Azure pricing changes	Azure service cost increases	Low–Medium	Azure Reserved Instances for compute; Savings Plans; architecture allows OSS swap at data tier

12.2 Planned Evolution Gates

Gate	Trigger	Likely Evolution
Year 1	Landing Zone stable; first app in production	Activate Argo Rollouts canary; establish OTel baseline; begin MASVS audit
Year 2	Traffic > 500K MAU	Upgrade APIM to Premium for multi-region; evaluate Cosmos DB autoscale vs. provisioned
Year 3	Team > 20 mobile engineers	Formalise design system versioning; evaluate micro-frontend/modular architecture; second SBOM audit
Year 4–5	Platform review cycle	Assess React Native new-arch maturity vs. MAUI for greenfield; evaluate Azure Container Apps as AKS simplification; renegotiate RASP contract

13. Key Architecture Decision Records (ADR Summary)

ADR	Decision	Rationale	Trade-offs
ADR-01	Azure-primary; OSS at data/runtime layer	CAF mandate; maximise managed service benefits while preserving portability	Slightly higher ops burden for OSS components vs. full PaaS
ADR-02	PKCE + PAR for all public mobile clients	Prevents auth code interception; PAR eliminates parameter tampering	Slightly more complex auth flow; MSAL handles transparently
ADR-03	APIM Standard v2 (not Premium)	75% cost reduction vs. Premium for initial scale; v2 = modern ingress	No multi-region active-active until Premium upgrade at Year 2
ADR-04	AKS over Azure Container Apps for services	More control over networking, scaling, and workload identity	Higher ops complexity; mitigated by GitOps + KEDA
ADR-05	Offline-first with LWW default; CRDT opt-in	LWW covers 80% of use cases with low engineering overhead	CRDT complexity reserved for genuinely collaborative data
ADR-06	OTel as telemetry standard (not App Insights SDK directly)	Vendor-neutral signal collection; future-proof exporter swap	Minor configuration overhead; Azure Monitor OTel exporter is GA
ADR-07	AI confined to developer tooling & ops — not user product features	Reduces attack surface; avoids LLM latency in critical path; governance clarity	Product features must use deterministic logic only
ADR-08	Bicep as primary IaC; Terraform as portability fallback	Bicep gives ARM-native type safety; Terraform enables multi-cloud drift	Two IaC languages to maintain; bounded to Azure-only components for Bicep

This document should be reviewed annually and updated following each Azure service GA announcement relevant to mobile workloads, OWASP MASVS version releases, and organisational CAF maturity assessments.